

STAGE 2

STAGE 2: 기능안전 & 사이버보안

ISO 26262 (ASIL A~D), SOTIF, ISO 21434, UN R155/R156/R157 완전 정복

주요 참고 기관 및 표준

- ISO (ISO 26262:2018, ISO 21448, ISO 21434)
- UNECE WP.29 (UN R155, R156, R157)
- NIST (SP 800-82, CSF 2.0)
- ENISA (EU)
- NHTSA (미국)
- BSI Germany
- Uptane (IEEE/ISTO)
- CMU / Phil Koopman
- arXiv

본 문서는 자동차 소프트웨어 엔지니어를 위한 한국어 심화 교육 자료입니다. 국제 표준, 정부 규제, 업계 가이드라인을 종합하여 실무 중심으로 재구성했습니다.

STAGE 2: 기능안전 & 사이버보안

자동차가 생명과 직결된 기계인 만큼, 소프트웨어 결함으로 인한 사고 예방은 최고 우선순위입니다. 이 장은 기능안전(ISO 26262), 안전 운전 의도 보장(SOTIF/ISO 21448), 자동차 사이버보안(ISO 21434), UN 법규(R155/R156/R157)를 체계적으로 다룹니다.

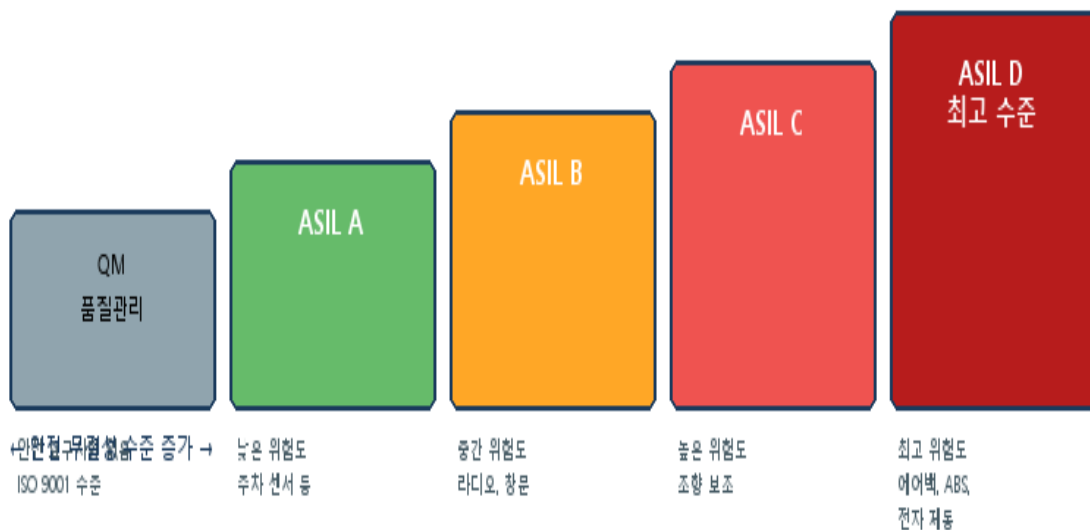


그림: ISO 26262 ASIL 등급 체계 (Automotive Safety Integrity Level)

[그림] ASIL 등급 결정 — 심각도·노출도·제어가가능성 매트릭스

1. ISO 26262 기능안전 개요

ISO 26262는 승용차(GVWR 3500kg 이하)의 E/E 시스템 기능안전을 다루는 국제 표준입니다. IEC 61508(산업용 기능안전 표준)을 자동차 영역에 맞게 적용한 것으로, 2011년 초판, 2018년 2판이 발행되었습니다. 소프트웨어, 하드웨어, 시스템 수준 모두를 포괄하는 포괄적 안전 표준입니다.

파트	제목	주요 내용
Part 1	어휘	용어 및 정의
Part 2	기능안전 관리	안전 조직, 역할, 책임, 안전 문화
Part 3	컨셉트 단계	Item 정의, 위험 분석 및 위험 평가, 안전 목표
Part 4	시스템 수준 개발	시스템 기술 안전 요구사항, 시스템 설계, TSC
Part 5	하드웨어 개발	하드웨어 아키텍처, HW 평가, PMHF
Part 6	소프트웨어 개발	SW 안전 요구사항, 아키텍처, 구현, 검증
Part 7	생산 및 운용	생산 프로세스, 유지보수, 폐차
Part 8	지원 프로세스	형상관리, 변경관리, 소프트웨어 도구 신뢰도

파트	제목	주요 내용
Part 9	ASIL 분해 및 통합	ASIL 분해, 공통 원인 고장, 독립성
Part 10	가이드라인	비규범적 적용 예시, 기술 배경
Part 11	반도체	반도체 하드웨어 특화 요구사항
Part 12	이륜차 적용	오토바이·스쿠터 특화 적용

2. HARA — 위험 분석 및 위험 평가

HARA(Hazard Analysis and Risk Assessment)는 Item의 오작동이 야기할 수 있는 위험 사건(Hazardous Event)을 식별하고 위험도를 평가하는 핵심 활동입니다. 결과로 안전 목표(Safety Goal)와 ASIL 등급이 결정됩니다.

2.1 ASIL 등급 결정 — 세 가지 파라미터

ASIL(Automotive Safety Integrity Level)은 3가지 파라미터의 조합으로 결정됩니다. 세 가지 각각 3~4단계로 평가하며, 조합 결과는 QM(Quality Management), ASIL A, B, C, D 중 하나가 됩니다.

파라미터	정의	등급 체계
심각도 (S)	위험 사건이 야기하는 최악의 인체 피해	S0 (부상 없음) ~ S3 (생명 위협)
노출도 (E)	운전자가 위험 상황에 처할 빈도	E0 (불가능) ~ E4 (매우 빈번)
제어가능성 (C)	운전자가 위험 사건을 회피할 수 있는 능력	C0 (일반적으로 제어) ~ C3 (거의 제어 불가)

예시: 전자 파워 스티어링(EPS) 갑작스러운 토크 잠금 → S3(최대 피해), E4(고속도로 빈번), C3(거의 제어 불가) → ASIL D.

ASIL 등급	의미	적용 예시	주요 요구사항
QM	Quality Management — 일반 품질 관리	실내 조명 제어	일반 개발 프로세스
ASIL A	최저 안전 무결성 수준	와이퍼 속도 제어	요구사항 추적성, 기본 안전 분석
ASIL B	중간 안전 무결성	도어 잠금 제어	HW 아키텍처 평가, 소프트웨어 단위 테스트
ASIL C	높은 안전 무결성	능동 서스펜션 제어	FMEA, 형식 검증, 고급 테스트 커버리지
ASIL D	최고 안전 무결성	에어백, ABS, EPS	이중화, MC/DC 테스트 커버리지, 독립 리뷰

3. 기능안전 개념 및 안전 아키텍처

3.1 FSC — 기능 안전 콘셉트

기능 안전 콘셉트(FSC: Functional Safety Concept)는 안전 목표로부터 도출된 시스템 수준의 안전 메커니즘입니다. 시스템이 어떻게 고장을 감지하고, 안전 상태로 전환하는지를 정의합니다.

- ▶ 안전 상태(Safe State): 더 이상 위험하지 않은 시스템 상태 (예: EPS → 수동 조향 가능 상태)
- ▶ 고장 반응 시간(FTTI: Fault Tolerant Time Interval): 고장 발생 후 안전 상태 도달까지의 허용 시간
- ▶ 비상 운전(Emergency Operation): 고장 감지 후 제한된 기능으로 계속 운전
- ▶ 페일 세이프(Fail-Safe): 고장 시 가장 안전한 상태로 전환
- ▶ 페일 오퍼레이셔널(Fail-Operational): 고장에도 지속적으로 동작 (자율주행에 필요)

3.2 시스템 안전 아키텍처 — 이중화 전략

고 ASIL(C/D) 시스템은 단일 고장이 안전 목표 위반으로 이어지지 않도록 이중화(Redundancy) 설계가 필요합니다. ASIL 분해(ASIL Decomposition)를 통해 ASIL D 요구사항을 ASIL B+ASIL B 또는 ASIL D+QM으로 분배할 수 있습니다.

이중화 방식	설명	예시
공간 이중화	독립적인 두 채널이 병렬 동작, 결과 비교	자율주행 브레이크 제어기 이중화
시간 이중화	동일 채널이 두 번 계산, 결과 비교	중요 계산 반복 수행
다양성 이중화	다른 알고리즘·하드웨어로 동일 결과 검증	자율주행 카메라 + 레이더 융합
모니터링 채널	메인 채널 감시 전용 경량 채널	MCU 내 Safety Monitor Core(예: AURIX Lock Step)

4. SW 개발 (ISO 26262 Part 6)

Part 6는 소프트웨어 개발에 관한 규범적 요구사항을 담습니다. SW 설계부터 단위 검증까지 ASIL 등급에 따른 구체적인 방법론과 검증 방법을 지정합니다.

활동	내용	ASIL A	ASIL B	ASIL C	ASIL D
SW 요구사항 명세	SW 안전 요구사항 도출	권장	권장	필수	필수
SW 아키텍처 설계	모듈 구조, 인터페이스	권장	필수	필수	필수
SW 단위 설계	상세 알고리즘, 자료구조	권장	권장	필수	필수
구조 커버리지 — 구문	모든 구문 실행	권장	필수	필수	필수
구조 커버리지 — 분기	모든 분기 실행	-	권장	필수	필수
구조 커버리지 — MC/DC	조건/결정 독립 커버리지	-	-	권장	필수

활동	내용	ASIL A	ASIL B	ASIL C	ASIL D
정적 분석	MISRA-C 준수	권장	필수	필수	필수
형식 검증	수학적 증명	-	-	권장	권장

4.1 MISRA-C: 자동차 SW 코딩 표준

MISRA-C(Motor Industry Software Reliability Association C 가이드라인)는 자동차 임베디드 SW를 위한 C 언어 코딩 표준입니다. MISRA-C:2012(+AMD1, AMD2)가 현재 최신 버전입니다. 144개 규칙이 "필수(Mandatory)", "요구(Required)", "조언(Advisory)" 세 카테고리로 분류됩니다.

- ▶ 동적 메모리 할당(malloc/free) 금지 — 메모리 단편화, 결정론성 위반
- ▶ 재귀 호출 금지 — 스택 오버플로우 위험
- ▶ 가변 인수 함수(va_arg) 금지 — 타입 안전성
- ▶ 암묵적 형변환 금지 — 명시적 캐스트 필수
- ▶ 함수 포인터 제한 — 제어 흐름 분석 복잡성
- ▶ 전역 변수 최소화 — 모듈 독립성

정적 분석 도구: PC-lint Plus, LDRA TBvision, Polyspace Bug Finder, Helix QAC가 MISRA-C 준수 확인에 사용됩니다.

5. HW 개발 — 랜덤 하드웨어 고장 지표

하드웨어 아키텍처 지표는 하드웨어가 안전 목표를 침해할 랜덤 고장에 얼마나 강건한지를 정량적으로 평가합니다. 두 가지 핵심 지표가 있습니다.

지표	전체 이름	정의	ASIL D 목표
SPFM	단일 점 고장 지표 (Single Point Fault Metric)	감지되거나 억제된 단일점 고장의 비율	$\geq 99\%$
LFM	잠재 고장 지표 (Latent Fault Metric)	감지되거나 억제된 잠재 고장의 비율	$\geq 90\%$
PMHF	시간당 확률론적 고장 지표	$10^{-8} \sim 10^{-9}$ 수준의 시간당 고장률 목표	$< 10^{-8}/h$

6. SOTIF — 안전 운전 의도 보장 (ISO 21448)

SOTIF(Safety Of The Intended Functionality)는 ISO 21448:2022로 표준화되었습니다. ISO 26262가 다루지 않는 기능 자체의 불충분성(Insufficiency)으로 인한 비합리적인 위험을 다룹니다. 주로 ADAS 및 자율주행 시스템에서 센서 한계, 환경 변수, 알고리즘 편향 등으로 발생하는 위험이 대상입니다.

구분	ISO 26262	ISO 21448 (SOTIF)
위험 원인	컴포넌트 고장 (랜덤·시스템)	기능 불충분성, 사용자 오용
대상 시스템	모든 E/E 안전 기능	ADAS, 자율주행 특히 적합
주요 방법론	HARA, FTA, FMEA	시나리오 기반 검증, 통계적 검증
검증 접근	V-모델 테스트, 커버리지	시뮬레이션, 도로 주행, ODD 정의

SOTIF 검증 영역(4사분면): ① 알려진 안전 시나리오(Known Safe) → 좋음, ② 알려진 위험 시나리오(Known Unsafe) → 수정 필요, ③ 알 수 없는 안전 시나리오 → 탐색 필요, ④ 알 수 없는 위험 시나리오(Unknown Unsafe) → 최소화 목표.

7. ISO 21434 — 자동차 사이버보안 엔지니어링

ISO 21434:2021은 도로 차량의 전 수명 주기 사이버보안 엔지니어링을 다루는 표준입니다. 설계→개발→생산→운용→폐차까지 사이버보안을 체계적으로 관리하기 위한 프로세스와 요구사항을 정의합니다.

주요 절	내용
4절: 일반	사이버보안 원칙, 역할, 책임
5절: 조직 사이버보안 관리	사이버보안 정책, 역량, 인식 제고
6절: 프로젝트 의존성 관리	공급업체 관리, 사이버보안 인터페이스 합의
7절: 지속적 사이버보안 활동	취약점 모니터링, 침해 대응, 업데이트
8절: 콘셉트 단계	Item 정의, TARA (위험 분석 및 위험 평가)
9절: 제품 개발	사이버보안 요구사항, 설계, 구현 가이드라인
10절: 사이버보안 검증	침투 테스트, 취약점 분석, 퍼징
11절: 생산 단계	생산 제어, 보안 자격 증명 프로비저닝
12절: 운용 및 유지보수	CSMS 운용, 사고 대응, 업데이트 배포
13절: 폐차	보안 데이터 삭제, 서비스 종료

7.1 TARA — 위협 분석 및 위험 평가

TARA(Threat Analysis and Risk Assessment)는 ISO 21434의 핵심 활동으로, 자산을 식별하고 위협을 분석하며 위험을 평가합니다.

- ▶ 1단계 — 자산 식별: 보호해야 할 자산(통신 버스, ECU 소프트웨어, 개인정보, OTA 채널) 목록화
- ▶ 2단계 — 위협 시나리오: 각 자산에 대한 위협 식별 (STRIDE 방법론 활용)
- ▶ 3단계 — 영향 평가: 기밀성·무결성·가용성·안전에 대한 피해 평가
- ▶ 4단계 — 공격 경로 분석: 공격 실현 가능성(Feasibility) 평가
- ▶ 5단계 — 위험 결정: CAL(Cybersecurity Assurance Level) 1~4 결정
- ▶ 6단계 — 위험 처리: 회피·감소·전가·수용 선택, 사이버보안 목표 도출

STRIDE 위협 모델링: S(Spoofing — 스푸핑), T(Tampering — 변조), R(Repudiation — 부인), I(Information Disclosure — 정보 누출), D(Denial of Service — 서비스 거부), E(Elevation of Privilege — 권한 상승).

8. UN R155 — 차량 사이버보안 법규 (WP.29)

UN R155는 UNECE WP.29 산하에서 개발된 사이버보안 차량 승인 규정입니다. 2022년 7월 1일부터 신형 차량 타입 승인에 의무 적용, 2024년 7월부터 모든 신차에 적용됩니다. 유럽, 일본, 한국 등에서 법적 효력이 있습니다.

요구사항	내용
CSMS 인증	사이버보안 관리 시스템(CSMS) OEM이 취득 필요
차량 타입 승인	각 차량 타입별로 사이버보안 요구사항 준수 증명
위협 식별	차량에 대한 사이버보안 위협 식별 및 관리
보안 조치	위협 완화 조치 구현 및 유효성 검증
현장 모니터링	양산 후 사이버 위협 지속 모니터링
침해 대응	사이버 침해 감지 및 대응 절차

UN R155 Annex 5는 차량에 적용 가능한 위협의 카탈로그(취약점 목록)를 제공합니다. OEM과 Tier1은 이 목록을 TARA의 출발점으로 활용해야 합니다.

9. UN R156 — OTA(Over-The-Air) 소프트웨어 업데이트

UN R156은 차량 소프트웨어의 무선(OTA) 업데이트를 관리하는 규정입니다.

SUMS(Software Update Management System)를 OEM이 인증받아야 하며, 안전하고 추적 가능한 방식으로 SW 업데이트를 수행하도록 요구합니다.

- ▶ 업데이트 전 안전성 검증 의무화
- ▶ SW 버전 관리 및 롤백 기능 요구
- ▶ 운전자 동의 프로세스 정의
- ▶ 업데이트 중단 복구 메커니즘 (Fail-Safe)
- ▶ 업데이트 이력 추적 및 보고 의무

10. UN R157 — ALKS (자율차선유지시스템)

UN R157은 Level 3 자율주행의 첫 번째 국제 법규로, ALKS(Automated Lane Keeping System)를 다룹니다. 시속 60km 이하 고속도로 환경에서의 자율주행을 규정하며, ODD(Operational Design Domain), Minimal Risk Condition(MRC), DSSAD(Data Storage System for ADS) 등을 요구합니다.

11. Uptane — 차량 OTA 보안 프레임워크

Uptane은 차량 소프트웨어 업데이트를 위한 오픈소스 보안 프레임워크입니다.

IEEE/ISTO 표준으로 채택되었으며, TUF(The Update Framework)를 차량 도메인에 적용한 것입니다. 주요 특징은 메타데이터 서명(Timestamp, Snapshot, Targets, Root), Director 레포지토리와 Image 레포지토리 분리, 시간 공격·롤백 공격 방지입니다.

12. NIST 사이버보안 프레임워크 (CSF 2.0)

NIST CSF(Cybersecurity Framework) 2.0은 자동차 OT/IT 시스템 사이버보안 관리에 활용됩니다. 6가지 기능(Govern, Identify, Protect, Detect, Respond, Recover)으로 구성되며, ISO 21434와 NIST CSF를 병행 적용하는 것이 모범 사례입니다.

CSF 기능	자동차 적용 예시
Govern(거버넌스)	CSMS 정책, 임원 사이버보안 책임
Identify(식별)	TARA 자산 목록, 취약점 데이터베이스 관리
Protect(보호)	SecOC, HSM, 보안 부트, 코드 서명
Detect(탐지)	IDS(침입 탐지), 비정상 CAN 트래픽 감지
Respond(대응)	SIRT 운영, 격리 프로시저, 고객 통보
Recover(복구)	OTA 패치 배포, 서비스 복원, 사후 분석

13. 기능안전 도구 체인

도구	제조사/공급원	기능	ASIL 적용
Polyspace Bug Finder	MathWorks	런타임 오류 정적 분석, MISRA-C	A-D
Polyspace Code Prover	MathWorks	형식 증명, 배열 오버플로우 검증	C-D
VectorCAST	Vector Software	단위 테스트, MC/DC 커버리지	A-D
LDRA TBvision	LDRA Technology	정적분석, 테스트 커버리지	A-D
Helix QAC	Perforce	MISRA-C 준수 정적 분석	A-D
Simulink Design Verifier	MathWorks	모델 수준 형식 검증, AFMF	A-D
BTC EmbeddedSpecifier	BTC Embedded Systems	SC-IVVQ, 요구사항 기반 테스트	A-D

14. 실무 — ISO 26262 프로젝트 진행

실제 ISO 26262 준수 프로젝트의 주요 마일스톤과 산출물입니다.

- ▶ 안전 계획(Safety Plan): 프로젝트 전체 안전 활동 계획, 역할·책임 정의
- ▶ DIA(Development Interface Agreement): OEM-Tier1 안전 책임 분담 계약
- ▶ 안전 케이스(Safety Case): 안전 목표 달성 증거의 구조적 논거
- ▶ FSR(Functional Safety Review): 독립 기능안전 검토
- ▶ FSA(Functional Safety Audit): 안전 프로세스 준수 감사
- ▶ Safety Gate: 각 개발 단계의 안전 요구사항 달성 확인

13. HARA 작성 실습 예제 — EPS 시스템

HARA 실습: 전자식 파워 스티어링(EPS) 시스템의 위험 분석을 예시로 설명합니다. EPS ECU 결함으로 발생할 수 있는 위험 사건과 ASIL 등급 결정 과정을 단계별로 보여줍니다.

위험 사건	심각도 S	노출도 E	제어 가능성 C	ASIL	안전 목표
EPS가 의도치 않은 좌/우 방향으로 조향 보조력을 가함	S3	E4	C3	ASIL D	EPS는 오작동 조향력을 가하지 않아야 한다
EPS가 조향 보조력을 완전히 상실함 (무보조)	S2	E4	C2	ASIL B	EPS는 정의된 최소 조향력을 유지해야 한다
EPS가 과도한 조향 보조력을 제공함	S3	E3	C3	ASIL C	EPS의 최대 조향 보조력은 규정값 이내이어야 한다

위험 사건	심각도 S	노출도 E	제어 가능성 C	ASIL	안전 목표
EPS 파워 소비가 배터리를 과방전시킴	S1	E4	C3	ASIL A	배터리 전압 12V 이하 시 EPS 보조 감소

안전 목표 도출 후: ① 기능 안전 개념(FSC) 정의 → ② 안전 목표를 시스템 레벨의 FSR(Functional Safety Requirements)로 분해 → ③ 시스템 FSR을 HW/SW 안전 요구사항(HWSR/SWSR)으로 배분. ASIL D 안전 목표는 하위 요소에 ASIL D 요구사항이 전달되거나 ASIL D → C+B 분해 적용.

ASIL 등급	소프트웨어 방법론 요구사항	코드 커버리지
ASIL A	구조적 분석, 기본 오류 처리	구문 커버리지(SC) 100%
ASIL B	ASIL A + 형식적 명세, 반방어적 프로그래밍	분기 커버리지(DC) 100%
ASIL C	ASIL B + 소프트웨어 결함 트리 분석	개조 조건/결정 커버리지(MC/DC) 100%
ASIL D	ASIL C + 공식 방법(Formal Methods), 다중 버전	MC/DC 100% (의무)

14. 하드웨어 안전 분석 (FMEDA) 심화

FMEDA(Failure Mode Effects and Diagnostic Analysis)는 ISO 26262 Part 5의 하드웨어 안전 분석 방법으로, 각 하드웨어 컴포넌트의 고장 모드와 진단 기능을 분석하여 SPFM(Single Point Fault Metric)과 LFM(Latent Fault Metric)을 계산합니다.

HW 안전 지표	정의	ASIL D 요구값
SPFM (단일 점 결함 메트릭)	안전 기능을 직접 위반하는 단일 점 결함이 포함되지 않는 비율	$\geq 99\%$
LFM (잠재 결함 메트릭)	안전 관련 잠재 결함이 포함되지 않는 비율	$\geq 90\%$
PMHF (확률론적 메트릭)	임무 시간 당 잔여 위험 사건 발생 확률	$< 10^{-8} / h$ (ASIL D)
DC (진단 커버리지)	감지된 결함 비율	특정 안전 메커니즘별로 정의

하드웨어 안전 메커니즘	기능	적용 예시
소프트웨어 CRC 모니터링	메모리 무결성 검사	ROM CRC 주기적 검사
CPU 실행 모니터 (Watchdog)	CPU 응답성 감시	독립 WD IC, 질문-응답 방식

하드웨어 안전 메커니즘	기능	적용 예시
전압 감시 (Voltage Monitor)	공급 전압 범위 검사	과전압/저전압 감지 IC
온도 감시 (Temperature Monitor)	MCU 온도 범위 검사	내부/외부 온도 센서
클록 모니터 (Clock Monitor)	클록 신호 주파수 감시	독립 RC 오실레이터 비교
중복 연산 (Redundant Calculation)	결과 교차 비교	ASIL D 요소에 1oo2D 구조

15. ASIL 분해 실습 — 에어백 시스템

ASIL 분해(ASIL Decomposition)는 하나의 ASIL D 요구사항을 두 개의 독립적인 채널로 분리하여 각각 낮은 ASIL 등급(예: ASIL B + ASIL B 또는 ASIL D + QM)으로 달성하는 방법입니다. 에어백 SRS 시스템 예시를 통해 설명합니다.

분해 전	분해 방법	분해 후 채널 A	분해 후 채널 B
SRS ECU 전개 제어 (ASIL D)	ASIL D → ASIL B + ASIL B	SRS 주 ECU (ASIL B)	SRS 독립 잠금 해제 회로 (ASIL B)
에어백 전개 명령 (ASIL D)	ASIL D → ASIL D + QM	전개 제어 펌웨어 (ASIL D)	충돌 진단 알고리즘 (QM)

독립성 요구사항: ASIL 분해의 두 채널은 충분히 독립적이어야 합니다(ISO 26262 Part 9). 공통 원인 고장(CCF), 종속 고장(DF)을 방지하기 위해 물리적 분리, 전원 분리, 소프트웨어 분리, 리뷰어 분리를 적용합니다. 독립 가정은 문서화하고 독립성 분석을 통해 검증해야 합니다.

16. ISO 21448 SOTIF 심화 분석

SOTIF(Safety of The Intended Functionality, ISO 21448:2022)는 결함 없는 시스템의 성능 한계나 의도적 기능 제한으로 인한 위험을 다루는 표준입니다. AI/ML 기반 ADAS 시스템에서 특히 중요합니다.

SOTIF 4분면	설명	대응 전략
알려진 안전한 시나리오 (1분면)	시스템이 올바르게 동작하는 시나리오	지속 모니터링
알려진 위험 시나리오 (2분면)	시스템 한계가 알려진 위험 시나리오 (ODD 밖)	시스템 개선 또는 경고
알려지지 않은 안전한 시나리오 (3분면)	시스템이 우연히 올바르게 동작하는 미탐색 영역	탐색 확장
알려지지 않은 위험 시나리오 (4분면)	아직 발견하지 못한 위험 시나리오	SOTIF 핵심 타겟

SOTIF 활동: ① 의도된 기능 정의 및 ODD 문서화 → ② 성능 한계 식별 → ③ 위험 시나리오 도출 (Scenario-Based Testing) → ④ 시뮬레이션 + 실도로 검증 → ⑤ 잔류 위험 평가 → ⑥ SOTIF 증거 수집. CARLA 시뮬레이터와 OpenSCENARIO를 활용한 시나리오 기반 검증이 주요 방법입니다.

17. ISO 21434 TARA 실습 — STRIDE 모델

TARA(Threat Analysis and Risk Assessment)는 ISO 21434의 핵심 사이버보안 활동입니다. 자산(Asset) → 위협(Threat) → 공격 경로(Attack Path) → 위험 값(Risk Value) → 보안 목표(Cybersecurity Goal) 순으로 분석합니다. STRIDE 모델이 위협 식별의 표준 방법론입니다.

STRIDE 위협	의미	자동차 적용 예시
S — Spoofing (스푸핑)	신원 위조	CAN ID 위조, ECU 신원 위장
T — Tampering (변조)	데이터 무결성 침해	CAN 메시지 위변조, ECU 플래시 조작
R — Repudiation (부인)	행위 부인	로그 삭제, 사고 기록 조작
I — Information Disclosure (정보 누출)	기밀 정보 노출	PIN, 인증서, 개인 데이터 탈취
D — Denial of Service (서비스 거부)	가용성 침해	CAN 버스 플러딩, ECU 응답 불가
E — Elevation of Privilege (권한 상승)	비인가 권한 획득	진단 접근 권한 탈취, ECU 루트 접근

위험 값 계산	매개변수	등급
영향 도(Impact)	안전, 재무, 운영, 개인정보 영향	Negligible/Moderate/Major/ Severe
공격 실현 가능성(Attack Feasibility)	공격 경로 난이도 (전문성, 자원, 기회)	Low/Medium/High/Very High
위험 값 (Risk Value)	영향도 × 실현가능성	1~5 (1: 무시, 5: 매우 높음)
보안 목표 (CSG)	위험 처리를 위한 목표	수용/처리/전가/회피

18. UN R155 CSMS 구현 실무 가이드

UN R155(사이버보안 규정)는 CSMS(Cyber Security Management System)을 자동차 유형 승인의 전제 조건으로 요구합니다. OEM과 Tier1 모두에게 영향을 미치며, 2022년 7월부터 신형 차종에 의무 적용되었습니다.

UN R155 요구사항 영역	세부 내용	증거 산출물
CSMS 범위 정의	조직 내 사이버보안 역할·책임·자원	CSMS 정책 문서
사이버보안 위험 관리	TARA 프로세스, 위험 처리 기록	TARA 보고서
보안 개발	Secure-by-Design, 코드 리뷰, 취약점 테스트	보안 테스트 보고서
생산 시 보안	ECU 공장 프로그래밍 보안, 키 관리	공장 프로그래밍 절차
사후 관리	취약점 모니터링, 패치 배포	PSIRT 프로세스 문서
사고 대응	사이버 침해 탐지 및 대응 절차	IRT(Incident Response Team) 문서

UN R156(SUMS)은 OTA 소프트웨어 업데이트 관리를 위해 별도의 승인을 요구합니다. SUMS는 CSMS의 하위 시스템으로 볼 수 있으며, 모든 OTA 업데이트에 대한 추적 가능성과 무결성이 요구됩니다.

19. Uptane 프레임워크 구현 심화

Uptane(IEEE/ISTO Std 6100.1.0)은 TUF(The Update Framework)를 자동차 OTA에 특화시킨 보안 프레임워크입니다. 온라인 공격과 오프라인 키 탈취 모두에 대한 강건한 방어를 제공합니다.

공격 유형	Uptane 방어 메커니즘
냉동 공격 (Freeze Attack)	구 버전 메타데이터를 최신으로 속이기 — Timestamp 메타데이터로 방어
재생 공격 (Replay Attack)	이전 업데이트 재전송 — Snapshot 버전 번호로 방어
무한 루프 공격 (Endless Data)	악의적으로 큰 이미지 전송 — Targets 메타데이터의 파일 크기 사전 검증
MitM 공격	통신 중간 위변조 — 오프라인 서명된 메타데이터로 방어
악성 업데이트	올바른 채널에서 악성 이미지 배포 — Root 신뢰 앵커 + 이미지 해시 검증
키 유출 공격	Root 키 유출 — 오프라인 HSM 보관, 키 교체 절차

Uptane 구현 단계	수행 내용
1. 인프라 구축	Director 서버 + Image 서버 구축, Root CA 설정
2. 키 관리	Root, Targets, Snapshot, Timestamp 키 생성 (오프라인 Root)
3. ECU 등록	차량 VIN, ECU ID, 하드웨어 ID 등록
4. 이미지 서명	새 SW 이미지에 서명, Targets 메타데이터 업데이트
5. 업데이트 배포	차량이 Director에서 업데이트 지시 + Image에서 이미지 수신
6. ECU 검증	Primary ECU가 모든 메타데이터 체인 검증 후 Secondary에 배포

20. 기능안전 & 사이버보안 통합 (ISO 26262 + ISO 21434)

기능안전(ISO 26262)과 사이버보안(ISO 21434)은 상호 보완적이지만 충돌하는 경우도 있습니다. 예를 들어, 사이버보안을 위한 암호화가 안전 기능의 실시간성을 저해하거나, 안전을 위한 정보 노출이 사이버보안 위험을 높일 수 있습니다.

통합 고려사항	기능안전 관점	사이버보안 관점	해결 방안
진단 접근	비상시 즉각 접근 필요	무분별한 진단 접근은 위험	역할 기반 접근 제어 + 긴급 해제 절차
암호화 지연	실시간 제어에 지연 금지	암호화 필수	경량 MAC, 하드웨어 암호화 엔진 사용
OTA 업데이트	검증된 SW만 설치	업데이트 무결성 보장	Uptane + 코드 서명 + 롤백 보호
로깅	안전 사건 기록 필수	로그에 개인정보 포함 위험	개인정보 익명화 + 무결성 보호
키 관리	안전 기능 키 교체 절차 필요	키 유출 시 즉각 교체 필요	HSM 기반 키 관리, 단계적 교체

학습 체크리스트

아래 항목을 모두 이해하고 설명할 수 있으면 다음 단계로 진행하세요.

ISO 26262의 12개 파트와 각 파트의 주요 내용을 설명할 수 있다

HARA의 목적과 S·E·C 파라미터의 의미와 등급을 설명할 수 있다

ASIL A/B/C/D와 QM의 차이를 설명하고 예시를 들 수 있다

ASIL 분해(ASIL Decomposition)의 개념을 설명할 수 있다

FTTI(Fault Tolerant Time Interval)와 안전 상태의 개념을 설명할 수 있다

페일 세이프와 페일 오퍼레이셔널의 차이를 설명할 수 있다

MC/DC 코드 커버리지가 무엇이고 왜 ASIL D에서 요구되는지 설명할 수 있다

MISRA-C의 목적과 주요 금지 사항을 설명할 수 있다

ISO 26262와 ISO 21448(SOTIF)의 차이를 설명할 수 있다

TARA(위험 분석 및 위험 평가)의 6단계를 설명할 수 있다

STRIDE 위험 모델링 방법론을 설명할 수 있다

ISO 21434의 주요 절(4~13절)의 내용을 개략적으로 설명할 수 있다

UN R155의 CSMS 요구사항을 설명할 수 있다

UN R156 OTA 업데이트 요구사항을 설명할 수 있다

UN R157 ALKS의 ODD와 Minimal Risk Condition을 설명할 수 있다

Uptane 프레임워크의 핵심 개념을 설명할 수 있다

NIST CSF 2.0의 6가지 기능을 자동차 도메인에 적용하여 설명할 수 있다

한/영 용어집

한국어 용어	영문 용어	설명
기능안전	Functional Safety	기능 고장 부재에 기인하는 비합리적 위험 부재 (ISO 26262 정의)
자동차 안전 무결성 수준	ASIL (Automotive Safety Integrity Level)	기능안전 요구사항의 위험 분류 A~D (D가 최고)
품질 관리	QM (Quality Management)	ASIL 미적용, 일반 품질 관리로 충분한 기능
위험 분석 및 위험 평가	HARA (Hazard Analysis and Risk Assessment)	위험 사건과 ASIL 등급 결정을 위한 체계적 분석
심각도	Severity (S)	HARA에서 위험 사건이 야기하는 최악의 피해 등급 S0~S3
노출도	Exposure (E)	HARA에서 위험 상황에 처하는 빈도 E0~E4
제어가능성	Controllability (C)	HARA에서 운전자가 위험을 회피할 수 있는 능력 C0~C3
안전 목표	Safety Goal	HARA에서 도출된 최상위 수준의 안전 요구사항
고장 허용 시간 구간	FTTI (Fault Tolerant Time Interval)	고장 발생부터 안전 상태 도달까지 허용되는 최대 시간

한국어 용어	영문 용어	설명
기능 안전 개념	FSC (Functional Safety Concept)	안전 목표로부터 도출된 시스템 수준 안전 메커니즘
기술 안전 개념	TSC (Technical Safety Concept)	시스템 설계 수준에서 정의된 안전 메커니즘
단일점 고장 지표	SPFM (Single Point Fault Metric)	HW 단일점 고장에 대한 감지·억제 비율 지표
잠재 고장 지표	LFM (Latent Fault Metric)	HW 잠재 고장에 대한 감지·억제 비율 지표
안전 운전 의도 보장	SOTIF (Safety Of The Intended Functionality)	ISO 21448 — 기능 불충분성에 의한 비합리적 위험 방지
운용 설계 영역	ODD (Operational Design Domain)	자율주행 기능이 정상 동작하도록 설계된 조건 범위
위협 분석 및 위험 평가	TARA (Threat Analysis and Risk Assessment)	사이버보안 위협 식별, 위험 평가, 대책 수립 프로세스
사이버보안 보증 수준	CAL (Cybersecurity Assurance Level)	ISO 21434에서 위험 수준에 따른 보안 보증 요구 1~4
사이버보안 관리 시스템	CSMS (Cybersecurity Management System)	UN R155에서 요구하는 OEM의 사이버보안 관리 체계
소프트웨어 업데이트 관리 시스템	SUMS (Software Update Management System)	UN R156에서 요구하는 OTA 업데이트 관리 체계

한국어 용어	영문 용어	설명
스푸핑	Spoofing	STRIDE — 정체를 위장하는 사이버 위협
변조	Tampering	STRIDE — 데이터 또는 코드를 허가 없이 변경하는 위협
정보 누출	Information Disclosure	STRIDE — 권한 없는 정보 접근·유출 위협
서비스 거부	Denial of Service (DoS)	STRIDE — 시스템 가용성을 저하시키는 위협
권한 상승	Elevation of Privilege	STRIDE — 허가 없이 높은 권한을 획득하는 위협
보안 하드웨어 모듈	HSM (Hardware Security Module)	ECU 내 암호화 키 저장·연산을 수행하는 하드웨어 보안 모듈
보안 부트	Secure Boot	펌웨어 무결성 검증 후에만 시스템 부팅을 허용하는 메커니즘
침입 탐지 시스템	IDS (Intrusion Detection System)	차량 네트워크의 비정상 트래픽을 감지하는 시스템
페일 세이프	Fail-Safe	고장 발생 시 가장 안전한 상태로 자동 전환하는 설계 원칙
페일 오퍼레이셔널	Fail-Operational	고장 발생에도 제한된 기능으로 계속 동작하는 설계 원칙
안전 케이스	Safety Case	시스템이 충분히 안전하다는 것을 논리적으로 증명하는 문서 집합

29. ISO 26262 파트별 요구사항 — 개발팀 관점

ISO 26262는 12개 파트로 구성됩니다. 개발팀 역할별로 어느 파트가 핵심인지 이해하면 효율적으로 표준을 적용할 수 있습니다.

파트	제목	대상 팀	핵심 산출물
Part 1	용어 정의	전체	ASIL, 안전 목표, HARA 등 용어 정의
Part 2	기능안전 관리	품질·PM	안전 계획서, 역할/책임, 공급업체 관리
Part 3	시스템 레벨 개발	시스템 팀	HARA, 안전 목표, FSC, 시스템 설계
Part 4	HW 개발	HW 팀	HW 아키텍처, FMEDA, HW 안전 요구
Part 5	SW 개발	SW 팀	SW 안전 요구, 아키텍처, 단위 테스트, MC/DC
Part 6	SW 지원 프로세스	SW 팀	형상관리, 문서화, 검증 전략

파트	제목	대상 팀	핵심 산출물
Part 7	생산·운용·폐차	생산·품질	양산 제어, 필드 모니터링
Part 8	지원 프로세스	전체	인터페이스 관리, 도구 적격성, COTS
Part 9	ASIL 지향 분석	안전 팀	공존 분석, 의존적 고장 분석
Part 10	가이드라인	전체	ISO 26262 적용 지침 및 예시
Part 11	반도체	HW 팀	MCU/SoC 안전 메커니즘 요구사항
Part 12	자전거·모터사이클 등	관련팀	저용량 차량 적용 지침

30. FTA — 결합 수목 분석 심화

FTA(Fault Tree Analysis)는 최상위 위험 사건에서 하향식으로 원인을 분석하는 체계적 방법입니다. ISO 26262 Part 9에서 종속 고장 분석의 한 방법으로 사용됩니다. HARA에서 도출된 안전 목표 위반이 FTA의 최상위 사건(Top Event)이 됩니다.

FTA 기호	이름	의미
○ (원)	Basic Event	더 이상 분해하지 않는 기본 사건 (부품 고장)
사다리꼴	Undeveloped Event	아직 분석하지 않은 사건 (추후 전개)
AND Gate	AND 게이트	모든 입력이 동시에 발생해야 출력 발생
OR Gate	OR 게이트	입력 중 하나라도 발생하면 출력 발생
Transfer Symbol	이전 기호	FTA를 여러 페이지로 분리할 때 연결

정량 FTA: 각 기본 사건에 고장률(λ , FIT)을 부여하고 최상위 사건의 발생 확률(PFH)을 계산합니다. AND 게이트: $P = P1 \times P2$. OR 게이트: $P = 1 - (1-P1)(1-P2)$. ASIL D 안전 목표의 PFH 목표: $< 10^{-8}$ /h (Fail-Safe 시스템). FMEDA(Failure Mode Effects and Diagnostic Analysis)와 FTA를 함께 사용하여 HW 안전 메트릭(SPFM, LFM, PMHF)을

계산합니다.

31. 기능안전 도구체인 — Tool Qualification

개발에 사용하는 소프트웨어 도구가 안전 분석 결과에 영향을 미칠 수 있습니다. ISO 26262 Part 8 §11에서 도구 적격성 확인(Tool Qualification)을 요구합니다.

도구 유형	예시	영향 등급 (TCL)	적격성 방법
코드 생성기	Simulink Coder, TargetLink	TCL 3 (ASIL D)	검증 스위트, 형식 검증
컴파일러	GCC, Green Hills MULTI, IAR	TCL 2~3	컴파일러 검증 테스트, 객관적 증거
정적 분석 도구	Polyspace, Klocwork, Coverity	TCL 1~2	도구 오류/경고 리뷰
커버리지 도구	VectorCAST, TESSY	TCL 2	도구 계측 검증
모델링 도구	Simulink, SCADE	TCL 1~3 (용도별)	도구 사용 지침, 리뷰
형상관리 도구	Git, ClearCase	TCL 1	사용 지침, 접근 제어

Tool Confidence Level(TCL) 결정: $TD(\text{Tool Impact}) \times TI(\text{Tool Error Detection Confidence}) \rightarrow \text{TCL 1(낮음, 리뷰로 충분)} \sim \text{TCL 3(높음, 광범위한 검증 필요)}$. 도구 제조사가 제공하는 도구 적격성 키트(Tool Qualification Kit)를 활용하면 작업을 대폭 줄일 수 있습니다.

32. UN R155 CSMS 인증 절차 — OEM 관점

UN R155(사이버보안)는 OEM이 CSMS(Cybersecurity Management System)를 구축하고 Type Approval Authority(국가 형식 승인 기관)로부터 인증을 받도록 요구합니다. 한국은 국토교통부 산하 한국교통안전공단(TS)이 승인 기관입니다.

CSMS 인증 단계	내용	산출물
1. CSMS 구축	정책·절차·역할 정의, 사이버보안 문화 조성	CSMS 정책 문서, 조직 구성
2. TARA 수행	차량 유형별 위협 분석 및 위험 평가	TARA 보고서, CAL 결정
3. 보안 대책 적용	CAL에 따른 기술·운영 대책 구현	보안 설계 문서, 테스트 결과
4. 모니터링 체계 구축	필드 취약점 모니터링, 사고 대응 절차	VSOC 구성, 대응 절차서
5. 인증 신청	심사 기관(TÜV, Dekra 등)에 CSMS 문서 제출	심사 보고서
6. 형식 승인	차량 유형별 R155 적합성 확인	형식 승인 인증서
7. 정기 갱신	3년마다 CSMS 재인증, 취약점 패치 이력 제출	갱신 심사 보고서

33. 기능안전 + 사이버보안 통합 라이프사이클

ISO 26262(기능안전)과 ISO 21434(사이버보안)은 함께 적용되어야 합니다. 사이버공격이 안전 기능에 영향을 미칠 수 있고, 안전 메커니즘이 사이버보안을 약화시킬 수 있기 때문입니다. ISO/SAE 21434 §14에서 통합 분석을 권고합니다.

통합 분석 영역	도전 과제	해결 접근법
안전+보안 목표 충돌	보안 업데이트가 안전 검증 무효화	변경 영향 분석(CIA), 회귀 테스트 자동화
진단 접근 보안	UDS 진단이 공격 표면이 될 수 있음	SecurityAccess + 세션 제한, 진단 게이트웨이 방화벽
OTA 업데이트 안전	업데이트 중 안전 기능 중단 위험	배경 다운로드, 검증 후 활성화, Uptane
Fail-Safe vs 공격 거부	IDS 오탐이 Fail-Safe 트리거 가능	이중 검증, 허용 오차 설정
증거 통합	ASIL과 CAL 증거를 단일 safety case에 통합	통합 안전 케이스 문서 (SOTIF 포함)

34. SOTIF — 의도된 기능의 안전성 (ISO 21448)

SOTIF(Safety Of The Intended Functionality)는 ISO 26262가 다루지 않는 영역 — 결함 없이도 위험해질 수 있는 기능(ADAS, AI 인지 시스템)의 안전을 다룹니다. ISO 21448이 2022년 발표되었습니다.

SOTIF 개념	설명	예시
의도된 기능	시스템이 설계대로 작동하는 기능	ACC(크루즈 컨트롤) 정상 동작
Known Safe	알려진 안전 시나리오	일반 직선 도로 ACC 동작
Known Unsafe	알려진 위험 시나리오 (제거 목표)	빈 종이박스를 물체로 인식 → 급제동
Unknown Unsafe	미지의 위험 시나리오 (발견 목표)	특정 날씨·조명 조합에서만 발생하는 오인식
Unknown Safe	아직 검증 안 된 안전 시나리오	대부분의 실도로 주행 조건
SOTIF 목표	Unknown Unsafe → 충분히 낮은 수준으로 줄이기	실도로 주행 + 시뮬레이션 조합

SOTIF 검증 전략: ① 트리거 조건(Triggering Conditions) 식별 — ODD 내 위험 상황 목록 작성 ② Known Unsafe 시나리오 제거 — 시스템 기능 개선 ③ Unknown Unsafe 발견 — 대규모 시뮬레이션(OpenSCENARIO), 실도로 주행 ④ 잔류 위험 평가 — 수용

가능 수준 논증 ⑤ Safety Case 통합 — ISO 26262 + SOTIF + ISO 21434 통합 증거.

35. 기능안전 프로젝트 실무 체크리스트

실제 ISO 26262 프로젝트에서 자주 놓치는 항목들을 단계별로 정리합니다. 이 체크리스트는 심사(Audit)와 고객 리뷰 준비 시 활용할 수 있습니다.

학습 체크리스트

아래 항목을 모두 이해하고 설명할 수 있으면 다음 단계로 진행하세요.

- [계획] 안전 계획서(Safety Plan)에 외부 공급업체 책임 명시 완료
- [계획] 개발 인터페이스 협약(DIA) 고객 및 공급업체와 서명 완료
- [시스템] HARA 결과에서 모든 안전 목표 ASIL 결정 근거 문서화
- [시스템] FSC(기능안전 개념)가 모든 안전 목표를 커버 확인
- [HW] FMEDA 완료 및 SPFM/LFM/PMHF 메트릭 ASIL 요구 충족
- [SW] SW 안전 요구사항 추적 매트릭스 — 테스트까지 완전 추적 확인
- [SW] ASIL D: MC/DC 커버리지 100% 달성, 도구 커버리지 보고서 첨부
- [SW] MISRA-C:2012 컴플라이언스 보고서 및 일탈(deviation) 승인 완료
- [검증] 통합 테스트 결과 리뷰 및 미결 이슈 관리 현황 최신화
- [릴리스] Safety Case 문서 완성 및 독립 기능안전 심사원(IFSA) 리뷰 완료